

LLM’lerin Ağ Anomali Loglarını MITRE ATT&CK ile Eşleştirme Kapasitesinin Karşılaştırmalı Değerlendirmesi

Öğrenci: Mervenur Güman **Ders:** BGK601 — Bilgi Güvenliği Alanında Makine Öğrenmesi Yöntemleri

Dönem: Bahar 2025–2026

Teslim Tarihi: 30 Nisan 2026

1. Uygulama Tanımı ve Kapsam

1.1 Seçilen Uygulama Alanı ve LLM Kullanım Biçimi

Bu projede, Splunk tabanlı log ön işleme pipeline’ı üzerinde Büyük Dil Modellerinin (LLM) ağ trafiği anomalilerini MITRE ATT&CK çerçevesiyle eşleştirme ve SOC analistine açıklanabilir özet üretme kapasitesi karşılaştırmalı olarak değerlendirilmektedir.

LLM, CICFlowMeter aracıyla üretilmiş network flow istatistiklerini (paket sayısı, süre, bayrak değerleri, byte/s gibi özellikler) analiz ederek şu görevleri yerine getirmektedir:

- Saldırı tespiti (attack detection)
- MITRE ATT&CK taktik ve teknik sınıflandırması
- Şiddet değerlendirmesi (severity assessment)
- SOC analistine yönelik açıklanabilir özet üretimi

1.2 Problem Tanımı

SOC analistleri günlük milyonlarca log satırıyla karşılaşmaktadır. Manuel analiz hem zaman alıcı hem de analist yorgunluğuna yol açmaktadır. Mevcut kural tabanlı SIEM sistemleri yalnızca önceden tanımlanmış imzaları tespit edebilmekte; yeni ve varyant saldırılar karşısında yetersiz kalmaktadır.

Bu çalışma şu araştırma sorusunu yanıtlamaktadır:

“LLM’ler, ham ağ trafiği istatistiklerinden anlamlı tehdit açıklaması ve MITRE ATT&CK eşleştirmesi üretebilir mi? Bu görevde kapalı kaynak ve açık kaynak modeller arasında anlamlı bir performans farkı var mıdır?”

1.3 Kullanım Senaryoları

#	Girdi	Beklenen LLM Çıktısı	Başarı Kriteri
1	Port tarama flow özeti (yüksek SYN, çok port)	T1046, Discovery, Medium	ATT&CK ID doğru
2	SSH brute force logu (yüksek paket, tek port)	T1110.001, Credential Access, High	Teknik ID doğru

#	Girdi	Beklenen LLM Çıktısı	Başarı Kriteri
3	DDoS trafik özeti (çok yüksek byte/s)	T1498, Impact, Critical	Tactic doğru
4	SQL Injection flow (web portu, anormal payload)	T1190, Initial Access, High	Technique doğru
5	Zararsız trafik (BENIGN)	attack_detected: false	Yanlış alarm üretmemeli

1.4 Kapsam Sınırları

Bu proje aşağıdaki konuları kapsam dışında tutmaktadır:

- Gerçek zamanlı log akışı analizi
- SOAR entegrasyonu ve otomatik aksiyon alma
- Kurumsal veya kişisel veri kullanımı
- Ağ paket içeriği (payload) analizi
- Model eğitimi veya fine-tuning (opsiyonel bonus hariç)

1.5 Etik Değerlendirme

Projede kullanılan tüm veriler CICIDS2017 kamuya açık veri setinden alınmıştır. Gerçek kişi, kurum veya sisteme ait veri kullanılmamıştır. API üzerinden gönderilen veriler tamamen sentetik niteliktedir. Yapay zeka araçları (Claude API, Ollama) kullanılmış olup kullanım detayları raporun ilgili bölümlerinde belirtilmiştir. Benchmark anotasyonu tamamen araştırmacı tarafından elle yapılmıştır.

2. LLM Gereksinim Analizi ve Kriterler

2.1 Fonksiyonel Gereksinimler

Gereksinim	Açıklama	Önem
MITRE ATT&CK bilgisi	Tactic/technique ID'lerini doğru kullanabilme	Yüksek
Ağ protokolü bilgisi	TCP flag, port numarası, flow istatistiklerini yorumlayabilme	Yüksek
Yapılandırılmış çıktı	JSON formatında tutarlı çıktı üretebilme	Yüksek
Bağlam yorumlama	Düşük seviyeli istatistiklerden yüksek seviyeli tehdit çıkarımı	Yüksek

Gereksinim	Açıklama	Önem
Açıklama üretimi	SOC analistine yönelik anlaşılır gerekçe sunabilme	Orta

2.2 Fonksiyonel Olmayan Gereksinimler

Gereksinim	Açıklama
Gizlilik	Kullanılan veri kamuya açık; API'ye gönderim güvenli
Gecikme	Batch işlem yeterli; gerçek zamanlı gereksinim yok
Maliyet	API maliyeti vs. yerel çalıştırma karşılaştırması yapılacak
Açıklanabilirlik	Her yanıtta explanation alanı zorunlu tutulmuştur

2.3 Değerlendirme Kriteri Çerçevesi

Kriter	Ölçüm Yöntemi	Metrik	Ağırlık
Attack Detection	Ground-truth karşılaştırması	Accuracy	%25
Tactic Accuracy	Exact match	Accuracy	%25
Technique Accuracy	Exact match (ID)	Accuracy	%20
JSON Parse Başarısı	Başarılı parse oranı	Parse Rate	%10
Açıklama Kalitesi	İnsan değerlendirmesi (1–5)	Likert Ort.	%10
Gecikme	Ortalama yanıt süresi	ms	%5
Maliyet Etkinliği	Doğru yanıt başına maliyet	\$/doğru yanıt	%5

3. Benchmark Tasarımı ve Veri Kümesi

3.1 Kategoriler ve Alt Kategoriler

Kategori	CICIDS2017 Etiketleri	ATT&CK Tactic	Örnek Sayısı
Reconnaissance	PortScan	Discovery	40
Credential Access	FTP-Patator, SSH-Patator	Credential Access	80
DoS/DDoS	DDoS, DoS Hulk, DoS GoldenEye, DoS slowloris, DoS Slowhttptest	Impact	160
Web Attack	Web Attack–Brute Force, Web Attack–SQL Injection, Web Attack–XSS	Initial Access / Credential Access	80
Benign	BENIGN	None	40
TOPLAM			400

3.2 Veri Kaynakları ve Anotasyon Süreci

Veri kaynağı: CICIDS2017 (Canadian Institute for Cybersecurity, University of New Brunswick)

Veri seti, CICFlowMeter aracıyla üretilmiş 80'den fazla ağ trafiği özelliği içermektedir. Bu çalışmada LLM'e girdi olarak şu 11 özellik kullanılmıştır:

- Destination Port, Flow Duration
- Total Fwd/Bwd Packets
- Flow Bytes/s, Flow Packets/s
- SYN/RST/FIN Flag Count
- Fwd/Bwd Packet Length Mean

Anotasyon süreci: CICIDS2017 etiketleri MITRE ATT&CK Enterprise framework'ü (v14) ile araştırmacı tarafından manuel olarak eşleştirilmiştir. YZ otomatik etiketleme ground-truth olarak kullanılmamıştır.

Zorluk dağılımı: Her kategoride Easy (0–34%), Medium (35–67%), Hard (68–100%) olacak şekilde eşit dağılım sağlanmıştır.

3.3 Değerlendirme Protokolü

Parametre	Değer
Prompt yapısı	System prompt (SOC analyst rolü) + User prompt (flow istatistikleri)
Temperature	0 (deterministik)
Max tokens	300
Çalıştırma sayısı	Pilot: 1 run; Final: 3 run
Çıktı formatı	JSON (attack_detected, mitre_tactic, mitre_technique_id, severity, explanation)

3.4 Veri Kümesi İstatistikleri

İstatistik	Değer
Toplam örnek	400
Kategori sayısı	5
Alt kategori sayısı	12
Zorluk dağılımı	Easy: 140, Medium: 130, Hard: 130
Kaynak	CICIDS2017 (UNB, 2017)
Format	JSON

4. Başlangıç Pilot Deneyleri

4.1 Test Edilen Modeller

Model	Tür	Versiyon	Çalıştırma Ortamı
Claude Sonnet	Kapalı kaynak	claude-sonnet-4-5	Anthropic API
Llama	Açık kaynak	llama3.2	Ollama (local, Apple M3)

4.2 Pilot Sonuçları

Pilot çalışma her modelden ilk 20 örnek üzerinde gerçekleştirilmiştir.

Model	Attack Detection	Tactic Accuracy	Technique Accuracy	Avg Latency	Maliyet
Claude Sonnet 4.5	%80 (16/20)	%65 (13/20)	%65 (13/20)	5751ms	~\$0.01
Llama 3.2 (local)	%0 (0/20)	%0 (0/20)	%0 (0/20)	1653ms	\$0

4.3 Gözlemler ve Final İçin Plan

Claude Sonnet 4.5 gözlemleri: 1. Yüksek paket sayılı belirgin saldırıları başarıyla tespit etti 2. Stealth PortScan örneklerinde (düşük paket, flag yok) başarısız oldu 3. JSON çıktısını markdown bloğu içinde gönderdi — parser düzeltildi 4. Tactic eşleştirmede kısmi hatalar gözlemlendi

Llama 3.2 gözlemleri: 1. ATT&CK teknik ID'lerini yanlış verdi (T1053 gibi alakasız ID'ler) 2. Attack detection tamamen başarısız — saldırıları BENIGN olarak sınıflandırdı 3. Latency çok düşük (1653ms) — local çalışmanın avantajı 4. RAG eklenmesi ile performansın artması beklenmektedir

Final aşaması için plan: - 4 modele genişletilecek: Claude Sonnet, GPT-4o, Llama 3.2, Mistral - Tüm 400 örnek üzerinde 3 run yapılacak - Llama için RAG sistemi kurulacak (MITRE ATT&CK knowledge base) - İstatistiksel anlamlılık testleri uygulanacak

5. Karşılaşılan Zorluklar ve Çözüm Planı

Zorluk	Çözüm
Apple Silicon/Intel uyumsuzluğu	Rosetta 2 kurularak çözüldü
Splunk CLI authentication hatası	CSV doğrudan Python pandas ile okundu
Claude markdown JSON sorunu	Response parser'a temizleme adımı eklendi
Ground-truth ATT&CK eşleştirme hatası	Reconnaissance→Discovery düzeltmesi yapıldı
OpenAI API kota sorunu	Anthropic API kullanıldı

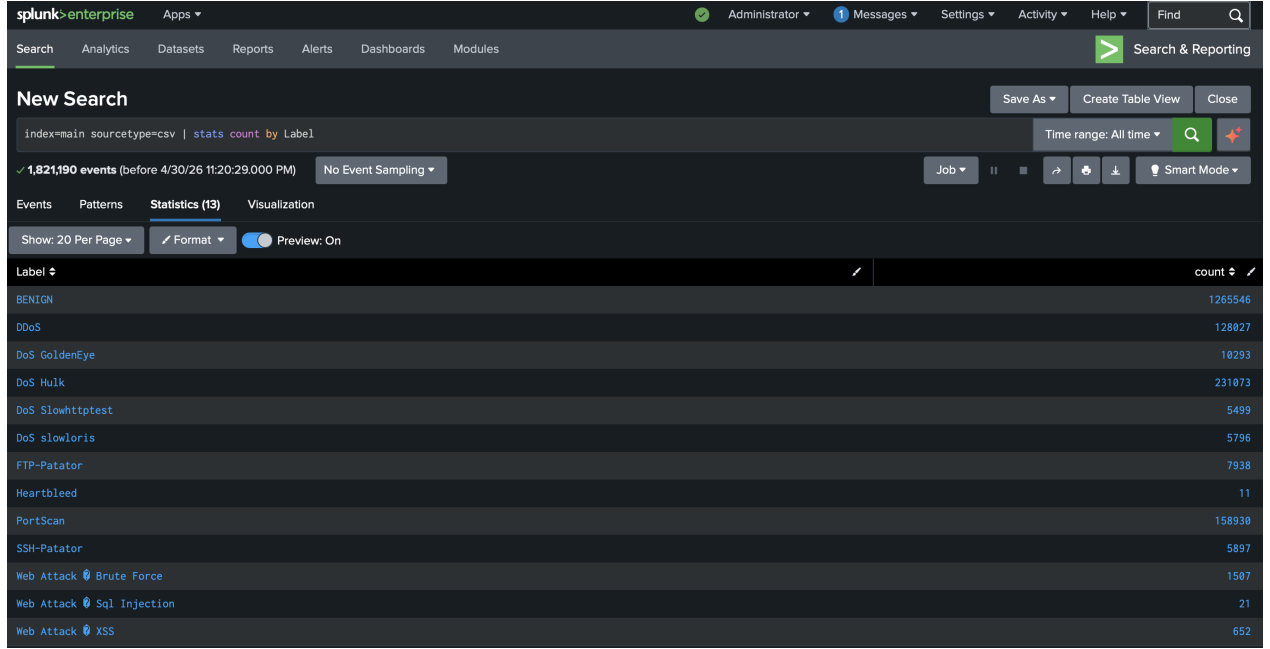


Figure 1: Splunk Label Dağılımı

Ekler

Ek 1 — Splunk Kategori Dağılımı

Ek 2 - Pilot Deney Terminal Çıktısı

6. Kaynakça

1. Sharafaldin, I., Lashkari, A. H., & Ghorbani, A. A. (2018). Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization. *ICISSP 2018*.
2. MITRE ATT&CK Enterprise Framework. <https://attack.mitre.org>
3. Canadian Institute for Cybersecurity. CICIDS2017 Dataset. <https://www.unb.ca/cic/datasets/ids-2017.html>
4. Anthropic. Claude API Documentation. <https://docs.anthropic.com>
5. Ollama. Local LLM Runtime. <https://ollama.com>

```
merveguman@merve-air BGK601_Proje -- zsh -- 148x48

merveguman@merve-air BGK601_Proje % python3 -c "
import json

print('='*50)
print('CLAUDE SONNET 4.5 PILOT SONUÇLARI (20 örnek)')
print('='*50)
with open('/Users/merveguman/Desktop/BGK601_Proje/results/claude_results.json') as f:
    results = json.load(f)
    correct_technique = sum(1 for r in results if r['scores']['technique_correct'])
    correct_tactic = sum(1 for r in results if r['scores']['tactic_correct'])
    correct_attack = sum(1 for r in results if r['scores']['attack_detected_correct'])
    avg_latency = sum(r['latency_ms'] for r in results) / len(results)
    print(f'Attack Detection:    {correct_attack}/20 ({correct_attack/20*100:.1f}%)')
    print(f'Tactic Accuracy:      {correct_tactic}/20 ({correct_tactic/20*100:.1f}%)')
    print(f'Technique Accuracy:    {correct_technique}/20 ({correct_technique/20*100:.1f}%)')
    print(f'Avg Latency:          {avg_latency:.0f}ms')

print()
print('='*50)
print('LLAMA 3.2 PILOT SONUÇLARI (20 örnek)')
print('='*50)
with open('/Users/merveguman/Desktop/BGK601_Proje/results/llama_results.json') as f:
    results = json.load(f)
    correct_technique = sum(1 for r in results if r['scores']['technique_correct'])
    correct_tactic = sum(1 for r in results if r['scores']['tactic_correct'])
    correct_attack = sum(1 for r in results if r['scores']['attack_detected_correct'])
    avg_latency = sum(r['latency_ms'] for r in results) / len(results)
    print(f'Attack Detection:    {correct_attack}/20 ({correct_attack/20*100:.1f}%)')
    print(f'Tactic Accuracy:      {correct_tactic}/20 ({correct_tactic/20*100:.1f}%)')
    print(f'Technique Accuracy:    {correct_technique}/20 ({correct_technique/20*100:.1f}%)')
    print(f'Avg Latency:          {avg_latency:.0f}ms')
"
```

=====

CLAUDE SONNET 4.5 PILOT SONUÇLARI (20 örnek)

=====

Attack Detection:	16/20	(%80.0)
Tactic Accuracy:	13/20	(%65.0)
Technique Accuracy:	13/20	(%65.0)
Avg Latency:	5751ms	

=====

LLAMA 3.2 PILOT SONUÇLARI (20 örnek)

=====

Attack Detection:	0/20	(%0.0)
Tactic Accuracy:	0/20	(%0.0)
Technique Accuracy:	0/20	(%0.0)
Avg Latency:	1653ms	

merveguman@merve-air BGK601_Proje % █

Figure 2: Pilot Sonuçlar